

## Ingénierie sociale • Authentification

# Phishing assisté par IA : nos repères de détection sont périmés

*La faute d'orthographe, le ton maladroit, la formule générique : les trois signaux que l'on enseigne depuis quinze ans ont cessé d'être discriminants. Et la technique AiTM contourne le MFA sans jamais l'attaquer.*

|                  |                                                                     |
|------------------|---------------------------------------------------------------------|
| Date de veille   | 8 juillet 2026                                                      |
| Rédacteur        | Sami El Abdallaoui, stagiaire veille et contenus                    |
| Déclencheur      | Relecture du module de sensibilisation au phishing de la plateforme |
| Public visé      | Équipe pédagogique — impact direct sur les exercices de détection   |
| Temps de lecture | 6 minutes                                                           |

## À retenir

- Les analyses éditeurs situent entre 80 % et 86 % la part des messages de phishing comportant du contenu généré par IA. Les indices linguistiques ne trient plus rien.
- Un clone vocal crédible se fabrique à partir de quelques secondes d'audio public — interview, webinaire, vidéo d'entreprise.
- L'attaque **AiTM** ne vole pas le mot de passe et n'attaque pas le MFA : elle laisse la victime s'authentifier, puis capte le cookie de session émis après coup.
- Conséquence directe : TOTP et SMS ne protègent pas contre l'AiTM. Seul un MFA lié à l'origine — FIDO2, passkeys — apporte une réponse structurée.
- La contre-mesure humaine qui tient encore : la vérification par un **second canal** choisi par le destinataire, jamais par l'expéditeur.

## Pourquoi les anciens repères ne fonctionnent plus

La sensibilisation classique repose sur une hypothèse implicite : l'attaquant écrit mal, dans une langue qui n'est pas la sienne, en série. La génération de texte a supprimé les trois contraintes d'un coup. Le message est désormais sans faute, dans le registre de l'entreprise ciblée, et personnalisé à partir de sources ouvertes — profil LinkedIn, actualité de la société, nom d'un collègue réel, projet en cours.

Le phishing devient également **polymorphe** : chaque message est généré dynamiquement, ce qui neutralise les filtres à signature. Et il sort de la messagerie : les campagnes visent aussi les outils collaboratifs, les invitations d'agenda, les SMS et les QR codes.

### Le volet audio et vidéo

Le clonage vocal a franchi un seuil d'usage courant. Le cas le plus documenté à l'international reste celui d'un employé trompé lors d'une fausse visioconférence où plusieurs participants, dont son directeur financier, étaient synthétiques : environ 25 millions de dollars transférés avant détection. En France, la Banque de France a alerté en avril 2026 sur des deepfakes vidéo imitant son gouverneur.

## AiTM : la menace la plus sous-estimée

Adversary-in-the-Middle est un cas intéressant parce qu'il est contre-intuitif. L'attaquant place un proxy inverse entre la victime et le service légitime. Le déroulé, du point de vue de l'utilisateur, est parfaitement normal :

- La victime clique sur un lien et arrive sur une page qui est le *vrai* service, relayé par le proxy.
- Elle saisit son identifiant et son mot de passe, qui transitent vers le service réel.
- Elle valide son MFA — TOTP, notification push, SMS — et l'authentification réussit vraiment.
- Le service émet un cookie de session. Le proxy le capte au passage.
- L'attaquant rejoue le cookie et se retrouve authentifié, sans jamais avoir eu à casser quoi que ce soit.

C'est pour cela que « j'ai activé le MFA » n'est plus une réponse suffisante. Le MFA a fonctionné ; il a simplement été contourné par l'aval. Les facteurs FIDO2 et les passkeys résolvent le problème par construction : la signature est liée à l'origine du site, et le domaine du proxy ne correspond pas à celui du service légitime — l'authentification échoue d'elle-même.

## Ce qui reste efficace

- **MFA résistant au phishing** — FIDO2 / passkeys sur les comptes sensibles. C'est la seule mesure structurelle contre l'AiTM.
- **Vérification par second canal**, à l'initiative du destinataire : on rappelle sur le numéro connu, on ne rappelle jamais celui fourni dans le message.
- **Procédure, pas vigilance** — un seuil de virement au-delà duquel une validation à deux personnes est obligatoire ne dépend pas de l'état de fatigue d'un salarié un vendredi à 18 h.
- **Détection comportementale** plutôt que détection de contenu : une session rejouée depuis une autre géographie reste anormale, même avec un cookie valide.

### Ce que cela change pour nos contenus

— Notre exercice de détection de phishing note l'apprenant sur le repérage de fautes et d'adresses mal orthographiées. Il enseigne aujourd'hui un réflexe faux et devrait être réécrit autour de la vérification par second canal.

— Proposition d'un nouveau scénario : le joueur reçoit un message impeccable, contextuellement juste, et n'a qu'un seul bon coup à jouer — vérifier par un canal qu'il choisit lui-même.

— Ajouter un scénario AiTM au parcours authentification : faire constater que le MFA a réussi et que l'attaquant est quand même entré, puis faire déployer une passkey.

— Intérêt pédagogique fort pour le public NSI : le sujet touche aussi leur vie personnelle (clonage vocal, arnaques par visioconférence), ce qui améliore l'adhésion.

## Sources consultées

- Vectra AI — dossier « Les escroqueries liées à l'IA en 2026 », mars 2026 (reprend les analyses KnowBe4 / SlashNext et Hoxhunt)
- Banque de France — alerte publique sur les deepfakes vidéo, avril 2026, relayée par la presse spécialisée
- KnowBe4 — rapport sur le phishing multicanal piloté par IA, 2026
- CyberConform — « Phishing en entreprise : guide de protection 2026 », avril 2026

- ANSSI — recommandations sur l'authentification multifacteur et les mots de passe

*Réserve méthodologique : les pourcentages cités proviennent d'éditeurs de solutions anti-phishing, donc d'acteurs intéressés, et les méthodologies de mesure diffèrent d'un rapport à l'autre — c'est ce qui explique l'écart entre les chiffres. Ils sont retenus ici comme ordre de grandeur convergent, pas comme mesure exacte. Le mécanisme technique de l'AiTM, lui, est vérifiable indépendamment de toute statistique.*